M365-18 · Generative AI & Copilot Use in Microsoft 365

What organization data may be put into which assistant — and why deploying Copilot across a tenant whose sharing has never been reviewed is how an organization discovers what it had been over-sharing.

Field	Value
Document ID	M365-18
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 4 — IT Management owns this document and every decision in it. Tier 3 configures. Tier 1 and Tier 2 answer §3 from the table and escalate anything the table does not cover.
Primary audience	Every member of staff, for §2, §3 and Appendix A. IT administrators for §5, §7 and §8. IT Leadership and executive leadership for §4, §5 and §11.
Review cycle	Every six months for the first two years, then annually. This is the fastest-moving subject in the catalogue and an annual cycle is not sufficient. First review no later than six months after adoption.
Relationship to M365-11 and M365-14	Copilot does not create permission problems. It surfaces the ones already present. Those two documents, and the remediation behind them, are a prerequisite to deployment rather than a parallel workstream — see §5.

1. Purpose — and why this one is written early

In many organizations, nobody has yet done anything wrong with a generative AI tool — so far as IT is aware. That is the reason to write this now rather than the reason not to.

Every other document in this catalogue exists because something happened first — a guest invited with no sponsor, a mailbox request by reply-all, a user blocked for the third time. This one usually has no such ticket behind it, and should say so rather than dressing a general concern up as evidence. What it has instead is timing: assistant features are arriving inside tools the organization already pays for, switched on by vendors, with no purchase decision and no project to attach a review to. By the time there is an incident to point at, the practice will be established, and a policy that arrives after the habit is arguing with the habit.

This document answers one question — what organization data may be put into which assistant — and names the conditions that must be true before Copilot is deployed broadly. It does not write the organization's policy on AI use in people's own work product, which is senior leadership's (§6), and it does not decide the questions listed in §11, which need owners this document cannot assign.

The honest framing for executive leadership

This is not a document about whether AI is good or bad, and it takes no position on that. It is a document about a boundary — the edge of the tenant the organization has a contract for — and about what crosses it.

It is recommended for executive leadership approval rather than IT approval alone, because it states what may be done with organization data by people IT does not manage, in HR, hiring and business contexts where IT has no standing to decide. An IT-approved AI policy is an IT opinion.

2. The distinction almost everyone gets wrong

Almost every argument about AI at work is really an argument about one distinction that is rarely made out loud.

	An enterprise assistant, INSIDE the tenant	A consumer chatbot, OUTSIDE it
What it is	Microsoft 365 Copilot, or Copilot Chat signed in with a work account, under the data protection terms the organization already holds.	Any assistant the organization has no agreement with — a personal ChatGPT, Gemini, Claude or Copilot account, a free web tool, an app on a phone.
Where the content goes	Within the service boundary the organization has contracted for. Prompts and responses are not used to train the underlying model.	To a third party, on that third party's terms, which the organization has not read, negotiated or accepted.
What the organization can do afterwards	Search it, hold it, export it and account for it under M365-16, because it is inside the estate.	Nothing. No route to recall it, no audit trail, and no way to answer a question about it later.
What a paste into it is	Use of an organization tool with organization data. Ordinary.	A disclosure to a third party — regardless of intent, of whether anything bad follows, and of how careful the person was being.

The question to ask, every time

It is never "is AI allowed?". It is "which side of the tenant boundary is this tool on, and what have I just put across it?"

And the honest caveat: this distinction is genuinely hard to see from the user's chair. The consumer and enterprise versions of the same assistant frequently look identical, carry the same brand, sit at similar web addresses, and differ only by which account happens to be signed in. Blaming people for getting that wrong is not a control. §3 and Appendix A exist so that the answer is a lookup rather than a judgement made under time pressure.

3. What you may put where

Tool	What you may put in it	What you may never put in it
Microsoft 365 Copilot, signed in with your work account	organization material you already have access to — your mail, your files, meetings you attended, sites you belong to. It reaches what you can already reach and nothing else (§4).	Note the reverse risk instead: anything it shows you that you should not be able to see is a permissions defect to report (§4), not a finding to act on or forward.
Copilot Chat with work data protection, signed in with your work account	General questions, drafting, summarising and rewriting. Material you paste that is not sensitive under M365-15.	The five classes in Appendix A. And do not assume that because a colleague sent a link, they were using the protected version.
A consumer chatbot — a personal account, any provider	Public information. Your own general questions. Text you wrote yourself containing nothing about a named person, no unpublished organization business, and nothing from a system of record.	Any client record. Any personnel, payroll or conduct matter. Any unpublished organization document. Any named individual's circumstances. Anything from the HR system or another system of record. Anything under an NDA. Any credential.
AI features inside third-party software the organization already uses	Nothing, until the ACC-16 review has asked what the feature does with the data (§8). If nobody has asked, the answer is not known — and "not known" is not "fine".	Anything, until §8 has been done for that application.
AI note-takers and meeting bots from outside the tenant	Nothing. They do not join organization meetings by default and are not admitted without the organiser's decision (§7).	Anything at all. A bot in the room is a recording device belonging to somebody else.
Assistants embedded in developer or admin tooling	Code and configuration you wrote for the organization, where the tool runs under an organization agreement.	Anything containing secrets — connection strings, API keys, certificates, service account credentials — and any extract of live data used as test data.

- "Signed in with my work address" is not the same as "covered". A personal account can have a work address typed into it. What matters is whether the organization holds an agreement with the provider, and that is a list IT maintains and will answer on at Tier 1 (§9).
- If a tool is not on that list, treat it as consumer. That is the safe default and it is almost always the correct one.
- Nobody is in trouble for asking which column something is in. People get into difficulty by guessing quietly, and the organization would much rather answer the question.

4. Copilot inherits your permissions

This is the single most important operational fact in the document, and it is routinely offered as a reassurance when it is in fact the central risk. Copilot has no permissions of its own. It has yours. It can read what you can read and nothing else, which is exactly the right design — and it is precisely why it changes what "nobody will ever find that" means.

	Before	After
An over-shared site with 4,000 files and no navigation	Effectively invisible. Finding anything in it required knowing it existed, knowing what to search for, and being willing to look. Discovery was bounded by effort.	Findable by asking a question in plain English. The effort bound is gone.
A salary band in a spreadsheet in a folder somebody shared broadly years ago	Nobody stumbles across it.	Answers the question “what is the salary band for that role?” for anybody the link ever reached.
A permission granted for a project long finished and never removed	Dormant. It never mattered, because nobody went looking.	Live. It is now the difference between a document existing and a document being quoted.

> **Say this plainly to whoever asks for Copilot**
>
> Copilot does not create over-permissioning. It makes over-permissioning VISIBLE and EXPLOITABLE. The exposure was there the whole time; what changes is that it is now one question away instead of one archaeology project away.
>
> Deploying Copilot across a tenant whose sharing has never been reviewed is how an organization discovers what it had been over-sharing. That discovery happens either way. The only decision available is whether it happens during a permissions review that IT runs deliberately, or in a meeting where somebody reads out a number they should never have had.

4.1 Signs this is live in your organization, rather than in general

- Site ownership is not assigned across the estate. If a SharePoint issue can sit past its service target because nobody owns the site, then nobody is reviewing that site’s permissions either — and there are usually more of those than anyone has counted.
- Permissions are actively in flux. Retiring legacy file shares or reworking HR and payroll access (M365-13) means content moving between systems, which is content whose permissions are being re-derived — and re-derived permissions are where the mistakes live.
- “Anyone” links, “Everyone except external users”, and permissions inherited from a migration years ago all count as access for this purpose. None of them looks like access when you are browsing; all of them are access when you are asking.

4.2 What to do when Copilot shows you something you should not see

1. Stop reading it. This is not a test and there is nothing to be gained by confirming how bad it is.
2. Do not forward it, quote it, or mention its contents to colleagues — including as a warning. The second disclosure is the one that does the damage.
3. Report it to the service desk address, naming the site, library or file — not the contents.
4. It is handled as a permissions defect under M365-11, at P2, with the site owner engaged under M365-10. It is not a disciplinary matter for the person who found it, and IT says so in the ticket. That last step is the control. If finding something is treated as having done something, nobody reports the next one,

and the organization loses its only realistic route to discovering these before somebody less scrupulous does.

5. Prerequisites to any broad Copilot deployment

These are gates, not a wish list. Each one exists because Copilot's value and Copilot's risk both scale with the same thing: how much the assistant can reach.

#	Gate — what must be true before broad deployment	Owner	Document
1	Every SharePoint site has a named owner and a named deputy. Sites with no owner are assigned one or closed.	Tier 2 / Tier 3	M365-10
2	"Anyone" links are inventoried and expired, and org-wide sharing defaults are set deliberately rather than inherited.	Tier 3	M365-14
3	Permissions are remediated on the sites that matter first — HR, Payroll, Finance, Legal, the chief executive's office, and anything holding the sensitive classes of M365-15.	Tier 2, with site owners	M365-11
4	The classification decision is closed, or at minimum the four levels in M365-15 §3 are endorsed, so "sensitive" denotes something specific rather than something felt.	Executive leadership	M365-15
5	Legacy file-share content is migrated with reviewed permissions, or declared out of scope for the pilot.	Tier 2 / Tier 3	M365-13
6	It is settled how long prompts, responses and AI meeting notes are retained, and confirmed that they are discoverable.	Tier 3 reports, Tier 4 decides	M365-16 §6
7	This document has a named owner and an approved review date.	Head of IT	§11

> **The sequencing recommendation**
> Run a limited pilot with a named group whose sites have been reviewed FIRST, rather than a tenant-wide enablement followed by remediation. A pilot of twenty-five people in reviewed sites tells IT what it needs to know. A tenant-wide switch tells everybody else what IT did not know.
> And state the dependency honestly when the question is asked. M365-11 and M365-14 remediation is a prerequisite, not a parallel workstream and not something to catch up on afterwards. Where IT is small and most staff wear several hats, and that remediation is not funded and resourced, the truthful answer to "when can we have Copilot?" is "when that work is done", and IT should give that answer rather than a date it will not meet.

6. Work product, assessment and policy investigations

This document does not write the organization's policy on how generative AI may be used in people's own work product — assessed work, training assessments, hiring exercises — and should not be read as doing so. That policy belongs to senior leadership and to the managers who set the work. What follows is only what IT commits to, so that the policy can be written knowing where the technical boundary is.

- IT does not detect, adjudicate or report on AI use in work product. AI-detection tools are unreliable enough that acting on their output is unfair, and IT will not supply an accusation it cannot stand behind. This is stated in a document rather than left to be inferred, because in the absence of a stated position IT is asked to be the detector, and that is the worst available allocation of the responsibility.
- Where an investigation needs technical facts, IT supplies them under the same rules as ACC-15 §5 and M365-16 §8 — what was accessed, when, from where — and draws no conclusions. Everybody remains subject to the acceptable use policy in their use of organization-provided AI tools exactly as in everything else.
- Who receives organization-provided AI capability is a licensing decision with a business dimension (M365-20, §10). It is not made by IT alone and it is not made by default because a licence bundle changed.
- Where a team permits or requires AI use, the tool the organization provides is the one to point at, because it is the one inside the boundary. A policy that permits AI use while providing no sanctioned tool sends people to consumer services with their work and, often, with other people's names in it.

7. AI note-takers joining Teams meetings

The pattern is now common enough to plan for. An external participant brings a third-party note-taker, which joins the meeting as a participant, records, transcribes, and stores the transcript on a service the organization has no agreement with. A confidential organization meeting becomes a document on somebody else's platform, and nobody in the room decided that — the person who brought it usually does not think of it as a decision at all.

- The lobby is the control. External participants and unrecognised apps wait in it, and the organiser admits them (M365-08).
- A recording bot is a participant. If you would not admit a stranger with a recorder, do not admit their bot; the fact that it is software does not make it a smaller decision. Anybody bringing one says so before the meeting starts, and the organiser decides — "it joins automatically" is an explanation, not consent.
- For meetings involving client records, personnel matters, litigation or anticipated litigation, contract negotiation, or executive leadership business: no external note-takers, and the organiser states that in the invitation so it is settled before anybody arrives.
- Microsoft's own transcription and Copilot recap, inside the tenant, is a different thing under §2 — but it is still a recording, and M365-08's notification and consent rules apply to it unchanged. "It is only the AI summary" is not an exemption.
- Tenant settings: anonymous and external participants cannot record or transcribe; lobby defaults admit organisation members only. Tier 3 owns these; changes go through M365-21.

8. AI features switched on inside software the organization already uses

This is the least visible route and, over the next two years, probably the most likely. An application the organization already runs — already reviewed, already integrated, already trusted — ships an assistant in a routine update. Nobody bought it. Nobody reviewed it. It may be on by default, and it may be sending organization content to a model provider under terms that were not part of the original agreement.

The rule is short: an application review under ACC-16 must now ask this, at onboarding and again at renewal.

The question the review must now ask	What a usable answer looks like
Does this application include generative AI features today, or announced?	A specific answer naming the features, not “we are exploring AI”.
Where does content go — which model provider, in which jurisdiction, under whose terms?	A named provider and a named jurisdiction. “Our secure cloud” is not an answer.
Is organization content used for training or product improvement?	A contractual term, in writing. A marketing page saying “we never train on your data” is not a contract term and cannot be relied on.
Can the feature be disabled at tenant level, and is it off by default?	Yes/no, plus where the setting is. A feature that cannot be turned off is a decision to make now rather than later.
Does the vendor’s data processing agreement cover the AI processing, or does it predate it?	A dated DPA. Many in force today were signed before the feature existed.

- For applications already in service: Tier 3 reviews the estate by data sensitivity, starting with anything touching client records, HR or finance, and reports to Tier 4 within 90 days of approval.
- This is the hardest thing in the document to actually deliver, and it is worth saying so. It depends on vendors disclosing changes they have no obligation to announce, and no control the organization can build will catch all of it. The realistic mitigation is asking at renewal, reading release notes for the systems that matter, and treating a surprise as a finding rather than a failure.
- Where a vendor cannot or will not answer the questions above, that is itself the answer, and it belongs in front of Tier 4 rather than in a project plan.

9. What IT will and will not review

IT will	IT will not
Maintain the list of assistants covered by an organization agreement, and answer “is this tool on the list?” at Tier 1 without a ticket.	Monitor what individuals ask an assistant. There is no routine review of prompts and there will not be (ACC-15 §6).
Configure and monitor the tenant-side controls — Copilot licensing and scope, meeting policies, sharing defaults, sensitivity labels once classification is decided.	Detect or adjudicate AI use in work product, or supply a detection tool for that purpose (§6).
Review an application’s AI features at onboarding and at renewal under ACC-16 (§8).	Approve individual pieces of content for pasting. That judgement belongs to the person who holds the data, using §3.
Investigate a suspected disclosure like any other incident, without blame attaching to the person who reported it (GOV-03).	Assess a tool the organization has no agreement with. “Is this AI tool safe?” about a consumer service has one answer: it is outside the boundary, so §3 row three applies.

IT will	IT will not
Treat anything Copilot surfaces inappropriately as a permissions defect and fix the permission (§4.2), and say plainly when a request cannot yet be met safely.	Act as the organization's authority on AI in hiring, client decisions or research — those need their own owners (§11) — or deploy broadly ahead of §5 on the basis that remediation will follow. It does not follow; it gets deferred.

10. Licensing and cost

- Copilot licensing is per user per month and is material at organization scale. It is a budget decision under M365-20, not an entitlement that follows from having Microsoft 365.
- Assign by role and demonstrated need, review at 90 days, and reclaim from non-users exactly as with any other licence. An assigned licence nobody uses is the most expensive kind, and it is also the kind that survives a budget review because nobody notices it.
- Some assistant capability is included in licences the organization already holds and some is not, and that boundary moves — frequently, and without a project to attach the change to. Confirm what is included at the time rather than relying on this document, which cannot pin it down and does not pretend to.
- A free or consumer tier is not a cheaper route to the same capability. It is the other side of the boundary in §2, and adopting it to save money is buying a disclosure risk at a discount.
- A department funding its own licences is fine, and still goes through M365-20 and §5. Local funding does not create a local exemption from the prerequisites.

11. What this document deliberately does not decide

Stated openly rather than left as silence, because silence in a policy document reads as permission.

Question left open	Recommendation	Owner
Whether the organization buys Copilot, for whom, and when.	Not before §5. Then a reviewed pilot, then a decision with the pilot's findings in front of it.	Head of IT, decided at executive leadership
Who receives organization-provided AI capability.	Decide it deliberately rather than by licence bundle. Providing a sanctioned tool is usually safer than the alternative people will use.	Executive leadership with the Head of IT
The position on AI use in assessed work product.	Written by senior leadership with managers. This document commits IT to supplying facts and not verdicts (§6).	Executive leadership
Whether AI-assisted decision-making is permitted in hiring, credit or eligibility decisions, or conduct matters.	Not addressed here at all, and it needs its own policy. This is the highest-risk unaddressed question in the organization's AI position, because it is the one carrying regulatory and legal exposure.	Executive leadership

Question left open	Recommendation	Owner
Use of data held under third-party terms — grants, research agreements, client contracts.	Out of scope here. Such terms frequently prohibit exactly what an assistant does.	Executive leadership / contract owners
How long prompts, responses and AI notes are retained, and whether they are routinely searched.	Bring under an explicit retention policy rather than a platform default (M365-16 §6).	Head of IT, on Tier 3's report

The most serious finding in this document is about the document

M365-18 has no owner today. Until one is assigned, it is a draft that nobody is maintaining — and for a subject that changes this quickly, an unmaintained AI policy is worse than none, because people will cite it after it has stopped being true.

ACTION: the Head of IT is recommended as owner, with a first review no later than six months after adoption and six-monthly thereafter. If the organization is not prepared to own and maintain it at that cadence, the honest course is to publish only §2, §3 and Appendix A as standing guidance and leave the rest as an unadopted draft.

Owner: Head of IT. Approval route: executive leadership.

12. Service levels

Activity	Commitment (per GOV-06)
"Is this tool covered by an organization agreement?"	Answered at Tier 1 from the list, in the conversation.
Copilot surfacing content the user should not see (§4.2)	P2 — permission corrected within 1 coverage day; site owner engaged the same day.
Suspected disclosure to a consumer assistant	Treated as a security incident under GOV-03. Triage same coverage day.
AI feature discovered in an existing application	Logged and assessed under ACC-16 within 10 coverage days.
Copilot licence request	Assessed against §5 and M365-20. Where §5 is not met, the answer and its reason are given in writing within 5 coverage days.
Review of this document	Six-monthly. A missed review is escalated to the Head of IT, not silently deferred.

13. Records

Record	Held in	Retention
List of assistants covered by an organization agreement	IT register, published	Live, versioned

Record	Held in	Retention
Permissions defects surfaced by Copilot, and their remediation	Ticket, plus the M365-11 register	3 years
Suspected or confirmed disclosures	Security record (GOV-03)	7 years
ACC-16 AI questions and vendor answers	Application register	Life of the contract + 3 years
Executive leadership decisions on the §11 open questions	Governance record	Permanent
Prompt and response history, AI meeting notes	Per M365-16 §6 — currently undecided (§11)	Open

14. Related documents

ID	Title	Relationship
AUP	Your organization's acceptable use policy	The governing policy. This document is subordinate to it and must not contradict it.
Data Policy	Your organization's information security policy	What sensitive means until classification is decided.
M365-11	SharePoint & OneDrive Permission Management	§5 gate 3, and where §4.2 defects are fixed. A prerequisite, not a companion.
M365-14	External Sharing & Guest Access Governance	§5 gate 2. Sharing links are Copilot’s reach.
M365-10	SharePoint Site Request & Ownership	§5 gate 1. A site with no owner cannot be reviewed.
M365-15	Data Classification & Handling	What §3 means by sensitive.
M365-16	Retention, Legal Hold & eDiscovery	Copilot artefacts are retainable, discoverable content.
M365-08	Teams Meetings, Recording & Guest Participation	§7. The lobby is the control.
M365-20	License Assignment, Reclamation & Cost Attribution	§10.
ACC-16	Application Onboarding, SSO & SAML Claims	§8. The review must now ask the AI questions.
ACC-15	Acceptable Use & Credential-Sharing Standard	§6 monitoring position.
GOV-03	Security Incident Response	Where a suspected disclosure goes.
GOV-06	Service Commitments, Priority & Escalation	Supplies §12.

Appendix A — For everyone: the one-paragraph version, and the five things not to paste

Source text for the knowledge base, format per GOV-05. Publishable as it stands.

The one-paragraph version

Use the AI tools the organization provides, signed in with your organization account, and you are on safe ground: they work inside the same protected space as your email and your files, they only see what you can already see, and nothing you type is used to train anybody's model. Everything else — a personal ChatGPT account, a free tool you found, an assistant built into an app on your phone — sits outside that space, and anything you paste into it has left the organization. Not in a dramatic way, and probably with no consequence at all; but it has gone somewhere we have no agreement with, cannot get it back from, and cannot answer questions about later. So the question is never whether AI is allowed. It is which side of that line the thing in front of you is on. If you are not sure, ask us — it takes about ten seconds and nobody minds.

The five things not to paste — into anything outside the organization

1. Anything about a named client or customer	Their account, their records, a complaint, an email they sent you, a difficult situation you are trying to word carefully. Especially that last one — "help me write a sensitive email about a client" is the most natural request in the world, and it is the one that puts the most into the box.
2. Anything about a named colleague's employment	Pay, performance, a grievance, a health matter, a reference, a reorganisation that has not been announced. If you would not leave it on the printer, do not paste it.
3. Anything the organization has not decided yet	Draft budgets, draft policies, contract terms under negotiation, anything from a leadership paper. Unpublished is unpublished, whatever you are using it for.
4. Anything out of the HR system or another system of record	An export, a report, a screenshot, a list of IDs. If it came out of a system holding the organization's records, it does not go into a tool outside the organization.
5. Any password, key or access link	Yours or anybody else's, including in a block of configuration you are asking for help with. Assistants are very good at reading configuration and completely indifferent to what is in it.
And really the first one:	Anything you would not be comfortable seeing quoted back, with the organization's name attached. That test catches most of what the five above catch, and a few things they do not.

If you have already pasted something

Tell us. Nobody is looking to make an example of anyone, and this is a genuinely easy mistake — the organization-provided tools and the consumer ones frequently look identical and sit at almost the same web address. What matters is knowing what went where, so we can work out whether anything needs doing. Told early, it is usually a five-minute conversation. Found out later, it is not.

If Copilot shows you something you should not be able to see

It happens, and it is not your fault. Copilot can only reach what you already had access to, so if it surfaces a salary spreadsheet or somebody's personnel file, what it has actually found is a permission somebody set years ago and forgot. Please do not read on, do not send it to anyone — not even as a warning — and let the service desk know which site or file it was, without telling us what was in it. We will fix the permission. You have not done anything wrong by finding it, and reporting it is the most useful thing that can happen to that file.

A note about meetings

If somebody brings an AI note-taker to a meeting with you, they should say so first, and you are entitled to say no. If the meeting is about a client, a member of staff, a contract or anything confidential, the answer is no — say so in the invitation, so it is settled before everybody is in the room.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.